

VYHLÁŠKA

ze dne 26. září 2025

o bezpečnostních opatřeních poskytovatele regulované služby v režimu nižších povinností
Národní úřad pro kybernetickou a informační bezpečnost stanoví podle [§ 13 odst. 3](#) a [§ 15 odst. 3 zákona č. 264/2025 Sb., o kybernetické bezpečnosti](#), (dále jen „zákon“):

ČÁST PRVNÍ

ÚVODNÍ USTANOVENÍ

§ 1

Předmět úpravy

Tato vyhláška zpracovává příslušný předpis Evropské unie¹⁾ a pro poskytovatele regulované služby [regulované služby](#) v režimu nižších povinností (dále jen „povinná osoba [povinná osoba](#)“) upravuje

a)

obsah, způsob zavádění a provádění bezpečnostních opatření [bezpečnostních opatření](#) a

b)

stanovení významnosti dopadu kybernetického bezpečnostního incidentu [kybernetického bezpečnostního incidentu](#).

§ 2

Vymezení pojmů

Pro účely této vyhlášky se rozumí

a)

uživatelem [uživatel](#) fyzická nebo právnická osoba anebo orgán veřejné moci, který využívá aktiva [aktiva](#),

b)

privilegovaným uživatelem [privilegovaným uživatelem](#) uživatel [uživatel](#) nebo jiná osoba, jejíž činnost na technickém aktivu může mít významný dopad na bezpečnost regulované služby [regulované služby](#),

c)

administrátorem [administrátorem](#) privilegovaný uživatel [privilegovaný uživatel](#) nebo osoba zajišťující správu, provoz, užívání, údržbu a bezpečnost technického aktiva [technického aktiva](#),

d)

bezpečnostní politikou [bezpečnostní politikou](#) soubor zásad a pravidel, která určují způsob zajištění ochrany aktiva [aktiv](#).

ČÁST DRUHÁ

BEZPEČNOSTNÍ OPATŘENÍ

§ 3

Systém zajišťování minimální kybernetické bezpečnosti

(1)

Povinná osoba [Povinná osoba](#) při zajišťování kybernetické bezpečnosti

a)

zavede a provádí bezpečnostní opatření [bezpečnostní opatření](#), která jsou přiměřená bezpečnostním potřebám, a

b)

zavede a provádí alespoň bezpečnostní opatření [bezpečnostní opatření](#) podle [odstavců 2 až 6](#), [§ 4 až 6](#) a [§ 10](#).

(2)

Povinná osoba [Povinná osoba](#)

a)

stanoví přehled bezpečnostních opatření [bezpečnostních opatření](#) podle [přílohy č. 1](#) k této vyhlášce, který obsahuje přehled všech bezpečnostních opatření [bezpečnostních opatření](#), která

1.

byla povinnou osobou [povinnou osobou](#) zavedena, včetně popisu jejich zavedení,

2.

budou povinnou osobou [povinnou osobou](#) zavedena, včetně termínů pro jejich zavedení, priority jejich zavedení a určení osoby odpovědné za jejich zavedení, a

3.

nebyla zavedena, včetně odůvodnění jejich nezavedení,

b)

provede a dokumentuje alespoň jednou ročně aktualizaci přehledu bezpečnostních opatření [bezpečnostních opatření](#), včetně vyhodnocení účinnosti zavedených bezpečnostních opatření [bezpečnostních opatření](#),

c)

uchovává jednotlivé přehledy bezpečnostních opatření [bezpečnostních opatření](#) a jejich aktualizace alespoň po dobu 4 let.

(3)

Povinná osoba [Povinná osoba](#) v rámci řízení bezpečnostní politiky [bezpečnostní politiky](#) a bezpečnostní dokumentace

a)

stanoví bezpečnostní politiku [bezpečnostní politiku](#) a bezpečnostní dokumentaci k bezpečnostním opatřením [bezpečnostním opatřením](#) požadovaným touto vyhláškou,

b)

pravidelně přezkoumává a aktualizuje pravidla a postupy stanovené v bezpečnostní politice [bezpečnostní politice](#) a bezpečnostní dokumentaci a

c)

vynucuje dodržování pravidel a postupů stanovených v bezpečnostní politice [bezpečnostní politice](#) a bezpečnostní dokumentaci.

(4)

Povinná osoba [Povinná osoba](#) v rámci řízení aktiv [aktiv](#) stanoví pravidla pro používání a manipulaci technických aktiv [technických aktiv](#).

(5)

Povinná osoba [Povinná osoba](#) při uzavírání smlouvy s dodavatelem do stanoveného rozsahu [stanoveného rozsahu](#) podle [§ 12 zákona](#) zohlední hrozby [hrozby](#) a zranitelnosti [zranitelnosti](#) spojené s tímto dodavatelem, celkovou kvalitu produktů a postupů v oblasti kybernetické bezpečnosti tohoto dodavatele, včetně postupů bezpečného vývoje a na základě toho zajistí, aby smlouvy s tímto dodavatelem obsahovaly relevantní požadavky na smluvní ujednání uvedené v [příloze č. 2](#) k této vyhlášce.

(6)

Povinná osoba [Povinná osoba](#) v souvislosti s plánovanou akvizicí, vývojem a údržbou technických aktiv [technických aktiv](#) stanoví bezpečnostní požadavky v oblasti kybernetické bezpečnosti a vymáhá jejich dodržování, přičemž vychází z požadavků na bezpečnostní opatření [bezpečnostní opatření](#) podle této vyhlášky.

§ 4

Požadavky na vrcholné vedení

Statutární orgán povinné osoby [povinné osoby](#) nebo jiná osoba anebo skupina osob v obdobném řídicím postavení povinné osoby [povinné osoby](#) (dále jen „vrcholné vedení [vrcholné vedení](#)“) s ohledem na zajišťování minimální kybernetické bezpečnosti

a)

určí osobu pověřenou kybernetickou bezpečností, které svěří pravomoci potřebné k řízení a rozvoji kybernetické bezpečnosti, dohledu nad stavem kybernetické bezpečnosti a komunikaci s vrcholným

vedením [vrcholným vedením](#), přičemž pro výkon této činnosti

1.

absolvuje bez zbytečného odkladu odborné školení podle [§ 5 odst. 2 písm. d\)](#), nebo

2.

prokáže odbornou znalost v kybernetické bezpečnosti,

b)

absolvuje prokazatelně školení podle [§ 5 odst. 2 písm. a\)](#),

c)

zajistí dostupnost zdrojů potřebných pro zajišťování kybernetické bezpečnosti v souladu s přehledem bezpečnostních opatření [bezpečnostních opatření](#),

d)

se prokazatelně seznamuje se stavem plnění bezpečnostních opatření [bezpečnostních opatření](#) uvedeným v přehledu bezpečnostních opatření [bezpečnostních opatření](#) podle [§ 3 odst. 2 písm. a\)](#),

e)

prosazuje neustálé zlepšování zajišťování kybernetické bezpečnosti a za tímto účelem podporuje osobu pověřenou kybernetickou bezpečností a jiné relevantní osoby a

f)

stanoví prioritu obnovy primárních aktiv [primárních aktiv](#).

§ 5

Bezpečnost lidských zdrojů

(1)

Povinná osoba [Povinná osoba](#) v rámci bezpečnosti lidských zdrojů

a)

stanoví politiku bezpečného chování uživatelů [uživatelů](#), v jejímž rámci zohledňuje relevantní témata uvedená v [příloze č. 3](#) k této vyhlášce,

b)

stanoví pravidla rozvoje bezpečnostního povědomí vrcholného vedení [vrcholného vedení](#), uživatelů [uživatelů](#), administrátorů [administrátorů](#) a osoby pověřené kybernetickou bezpečností, včetně pravidel pro tvorbu hesel,

c)

zajistí kontrolu dodržování bezpečnostní politiky [bezpečnostní politiky](#) ze strany uživatelů [uživatelů](#), administrátorů [administrátorů](#) a osoby pověřené kybernetickou bezpečností a

d)

stanoví pravidla a postupy pro řešení případů porušení bezpečnostní politiky [bezpečnostní politiky](#).

(2)

Povinná osoba [Povinná osoba](#) v souladu s pravidly rozvoje bezpečnostního povědomí zajistí

a)

poučení vrcholného vedení [vrcholného vedení](#) o jeho povinnostech a o bezpečnostní politice [bezpečnostní politice](#), zejména v oblasti zajišťování kybernetické bezpečnosti, formou vstupních a pravidelných školení,

b)

vstupní školení v oblasti kybernetické bezpečnosti,

c)

pravidelná školení v oblasti kybernetické bezpečnosti a

d)

potřebná odborná teoretická i praktická školení administrátorů [administrátorů](#) a osoby pověřené kybernetickou bezpečností v souladu s jejich pracovní náplní.

(3)

Povinná osoba [Povinná osoba](#) vede přehledy o provedených školeních a seznamy školených osob podle [odstavce 2.](#)

§ 6

Řízení kontinuity činností

Povinná osoba [Povinná osoba](#) v rámci řízení kontinuity činností

a)

stanoví prioritu technických aktiv [technických aktiv](#), pořadí a postupy jejich obnovy a zohlední přitom stanovenou prioritu relevantního primárního aktiva [primárního aktiva](#) podle [§ 4 písm. f\)](#),

b)

stanoví povinnosti a odpovědnost konkrétních osob za jednotlivé činnosti pro zajištění kontinuity činností a k obnově podle [písmene a\)](#) a

c)

vytváří pravidelné zálohy informací [informací](#), dat [dat](#), konfigurací a nastavení technických aktiv [technických aktiv](#) nezbytných zejména pro účely obnovy regulované služby [regulované služby](#) pro případ kybernetického bezpečnostního incidentu [kybernetického bezpečnostního incidentu](#).

§ 7

Řízení přístupu

(1)

Povinná osoba [Povinná osoba](#) řídí přístup k aktivům [aktivům](#) a v rámci něj

a)

přidělí každému uživateli [uživateli](#) a administrátorovi [administrátorovi](#) přístupujícímu k aktivům [aktivům](#) přístupová práva a oprávnění na úroveň nezbytně nutnou k výkonu jejich práce a jedinečný identifikátor daného typu účtu, přičemž od sebe odděluje uživatelské a administrátorské účty jedné osoby,

b)

řídí identifikátory, přístupová práva a oprávnění účtů technických aktiv [technických aktiv](#),

c)

zavádí bezpečnostní opatření [bezpečnostní opatření](#) potřebná pro bezpečné používání mobilních zařízení a jiných obdobných technických aktiv [technických aktiv](#), popřípadě i bezpečnostní opatření [bezpečnostní opatření](#) spojená s využitím technických aktiv [technických aktiv](#), která povinná osoba [povinná osoba](#) nemá ve své správě,

d)

provádí pravidelné přezkoumání nastavení veškerých přístupových práv a oprávnění,

e)

zajistí bezodkladné odebrání nebo změnu přístupových práv a oprávnění při změně pozice nebo zařazení uživatelů [uživatelů](#) nebo administrátorů [administrátorů](#) a

f)

zajistí deaktivaci účtu a bezodkladné odebrání nebo změnu přístupových práv a oprávnění při ukončení nebo změně smluvního vztahu, na jehož základě došlo ke zřízení přístupu k aktivům [aktivům](#).

(2)

Povinná osoba [Povinná osoba](#) v rámci zajištění fyzické bezpečnosti zamezí neoprávněnému přístupu ke svým aktivům [aktivům](#) a předchází poškození, odcizení, zneužití aktiv [aktiv](#), neoprávněným zásahům do nich a narušení bezpečnosti poskytování regulované služby [regulované služby](#).

§ 8

Řízení identit a jejich oprávnění

(1)

Povinná osoba [Povinná osoba](#) pro řízení identit, přístupových práv a oprávnění používá nástroj, který zajišťuje

a)

řízení počtu možných neúspěšných pokusů o přihlášení,

b)

opětovné ověření identity po stanovené době nečinnosti,

c)

odolnost uložených a přenášených autentizačních údajů a

d)

řízení přístupových práv, oprávnění pro čtení a zápis informací [informací](#) a dat [dat](#) a změnu oprávnění.

(2)

Povinná osoba [Povinná osoba](#) pro ověření identity administrátorů [administrátorů](#), uživatelů [uživatelů](#) a technických aktiv [technických aktiv](#) využívá autentizační mechanismus, který je založený na vícefaktorové autentizaci s alespoň dvěma různými typy faktorů, nebo využívá autentizační mechanismus, který je založen na aktuálně odolné kontinuální autentizaci založené na modelu nulové důvěry.

(3)

Povinná osoba [Povinná osoba](#) do doby využívání autentizačního mechanismu podle [odstavce 2](#) využívá autentizaci pomocí kryptografických klíčů nebo certifikátů.

(4)

Povinná osoba [Povinná osoba](#) do doby využívání autentizačního mechanismu podle [odstavce 3](#) využívá nástroj založený na autentizaci pomocí identifikátoru účtu a hesla, kdy tento nástroj musí vynucovat pravidla

a)

délky hesla alespoň

1.

12 znaků pro účty uživatelů [uživatelů](#),

2.

17 znaků pro účty administrátorů [administrátorů](#),

3.

22 znaků pro účty technických aktiv [technických aktiv](#),

b)

bezodkladné změny výchozího hesla pro ověření identity technických aktiv [technických aktiv](#), přičemž nové heslo musí být vytvořeno náhodným řetězcem složeným z malých a velkých písmen, číslic a speciálních znaků,

c)

neomezující použití malých a velkých písmen, číslic a speciálních znaků,

d)

povinné změny hesla v intervalu alespoň jednou za 18 měsíců a

e)

neumožňující uživatelům [uživatelům](#) a administrátorům [administrátorům](#)

1.

zvolit si jednoduchá a často používaná hesla,

2.

tvořit hesla na základě mnohonásobně opakujících se znaků, přihlašovacích jmen, adres elektronické pošty, názvů systémů nebo obdobným způsobem a

3.

opětovného použití dříve používaných hesel s pamětí alespoň 12 předchozích hesel.

(5)

Povinná osoba [Povinná osoba](#) při řízení identit dále zajistí

- a)
důvěrnost při vytváření výchozích autentizačních údajů a při obnově přístupu,
- b)
změnu výchozího hesla nebo hesla sloužícího k obnově přístupu po jeho prvním použití,
- c)
zneplatnění hesla nebo identifikátoru sloužícího k obnově přístupu nejpozději do 24 hodin od jeho vytvoření,
- d)
bezodkladnou změnu přístupového hesla v případě důvodného podezření na jeho kompromitaci a
- e)
zabezpečení administrátorských účtů technických aktiv [technických aktiv](#) zejména určených pro případ obnovy po kybernetickém bezpečnostním incidentu [kybernetickém bezpečnostním incidentu](#) a využívá tyto účty pouze v nezbytně nutných případech.

§ 9

Detekce a zaznamenávání kybernetických bezpečnostních událostí

(1)

Povinná osoba [Povinná osoba](#) při detekci kybernetických bezpečnostních událostí [kybernetických bezpečnostních událostí](#) zajistí

- a)
ověření a kontrolu přenášovaných dat [dat](#) na perimetru komunikační sítě, včetně blokování nežádoucí komunikace,
- b)
použití nástroje pro nepřetržitou a automatickou ochranu před škodlivým kódem na technických aktivech, zejména na
 - 1.
serverech a
 - 2.
koncových stanicích,
- c)
řízení automatického spouštění obsahu, zejména u vyměnitelných zařízení a datových nosičů,
- d)
nepřetržité poskytování informací [informací](#) o relevantních detekovaných kybernetických bezpečnostních událostech [kybernetických bezpečnostních událostech](#) a včasné varování relevantních osob a
- e)
pravidelnou a bezodkladnou aktualizaci nástrojů pro nepřetržitou a automatickou ochranu před škodlivým kódem a dalších detekčních nástrojů a jejich pravidel.

(2)

Povinná osoba [Povinná osoba](#) za účelem detekce kybernetických bezpečnostních událostí [kybernetických bezpečnostních událostí](#) zaznamenává

- a)
bezpečnostní a relevantní provozní události detekované podle [odstavce 1](#) a bezpečnostní a relevantní provozní události technických aktiv [technických aktiv](#) na základě svých bezpečnostních potřeb a
- b)
u událostí podle [písmene a\)](#) následující informace [informace](#) o události:
 - 1.
datum a čas, včetně specifikace časového pásma,

2.

typ činnosti,

3.

jednoznačnou identifikaci technického aktiva [technického aktiva](#) a identifikaci účtu původce a

4.

úspěšnost nebo neúspěšnost činnosti.

(3)

Povinná osoba [Povinná osoba](#) uchovává záznamy bezpečnostních a relevantních provozních událostí po dobu, kterou si stanoví na základě svých bezpečnostních potřeb.

§ 10

Řešení kybernetických bezpečnostních incidentů

Povinná osoba [Povinná osoba](#) při řešení kybernetických bezpečnostních událostí [kybernetických bezpečnostních událostí](#) a kybernetických bezpečnostních incidentů [kybernetických bezpečnostních incidentů](#)

a)

zajistí, že uživatelé [uživatelé](#), administrátoři [administrátoři](#), osoby pověřené kybernetickou bezpečností a další zaměstnanci budou oznamovat neobvyklé chování technických aktiv [technických aktiv](#) a podezření na jakékoli zranitelnosti [zranitelnosti](#),

b)

vytvoří metodiku pro posuzování kybernetických bezpečnostních událostí [kybernetických bezpečnostních událostí](#) a kybernetických bezpečnostních incidentů [kybernetických bezpečnostních incidentů](#), včetně posuzování významnosti dopadu kybernetického bezpečnostního incidentu [kybernetického bezpečnostního incidentu](#) v souladu s [§ 14](#),

c)

zajistí detekci kybernetických bezpečnostních událostí [kybernetických bezpečnostních událostí](#),

d)

zajistí posuzování kybernetických bezpečnostních událostí [kybernetických bezpečnostních událostí](#) a kybernetických bezpečnostních incidentů [kybernetických bezpečnostních incidentů](#) v souladu s metodikou podle [písmene b\)](#),

e)

zajistí hlášení kybernetického bezpečnostního incidentu [kybernetického bezpečnostního incidentu](#) s významným dopadem podle [§ 15 zákona](#),

f)

zajistí vytvoření závěrečné zprávy o vyřešení kybernetického bezpečnostního incidentu [kybernetického bezpečnostního incidentu](#) s významným dopadem podle [§ 16 zákona](#).

§ 11

Bezpečnost komunikačních sítí

Povinná osoba [Povinná osoba](#) pro ochranu bezpečnosti komunikační sítě, a to zejména jejího síťového perimetru,

a)

zajistí segmentaci komunikační sítě, včetně oddělení provozního a zálohovacího prostředí,

b)

omezí odchozí a příchozí komunikaci na perimetru komunikační sítě na dobu nezbytně nutnou pro řádné zajištění poskytování regulované služby [regulované služby](#),

c)

užívá aktuálně odolné a bezpečné komunikační protokoly,

d)

v případě užití vzdáleného připojení do interní komunikační sítě nebo vzdálené správy technických aktiv [technických aktiv](#) regulované služby [regulované služby](#)

1.

omezí tato připojení na nezbytně nutná,

2.

zavede bezpečnostní opatření [bezpečnostní opatření](#), která zajistí důvěrnost a integritu těchto vzdálených připojení a vzdálené správy, a

3.

má přehled o uživatelích [uživatelích](#) a administrátorech [administrátorech](#), kteří tato vzdálená připojení nebo vzdálenou správu užívají.

§ 12

Aplikační bezpečnost

Povinná osoba [Povinná osoba](#) při zajišťování aplikační bezpečnosti regulované služby [regulované služby](#)

a)

zajistí bezodkladné aplikování schválených bezpečnostních aktualizací vydaných pro technická aktiva [technická aktiva](#),

b)

u technických aktiv [technických aktiv](#), která již nejsou výrobcem, dodavatelem nebo jinou osobou podporována

1.

vede jejich evidenci,

2.

zavede bezpečnostní opatření [bezpečnostní opatření](#), která zaručí obdobnou nebo vyšší úroveň bezpečnosti, a

3.

omezí jejich komunikaci v komunikační síti na nezbytně nutnou,

c)

provádí pravidelné skenování zranitelností [zranitelností](#) relevantních technických aktiv [technických aktiv](#) a aplikuje přiměřená bezpečnostní opatření [bezpečnostní opatření](#) na základě zjištěných výsledků.

§ 13

Kryptografické algoritmy

(1)

Povinná osoba [Povinná osoba](#) při zajištění bezpečnosti technických aktiv [technických aktiv](#) a jejich komunikace

a)

používá aktuálně odolné kryptografické algoritmy,

b)

prosazuje bezpečné nakládání s kryptografickými algoritmy a

c)

zohledňuje doporučení a metodiky v oblasti kryptografických algoritmů vydané Národním úřadem pro kybernetickou a informační bezpečnost.

(2)

Povinná osoba [Povinná osoba](#) zajišťuje bezpečnou

a)

hlasovou, audiovizuální a textovou komunikaci, a to včetně e-mailové komunikace, a

b)

nouzovou komunikaci v rámci organizace.

ČÁST TŘETÍ

STANOVENÍ VÝZNAMNOSTI DOPADU KYBERNETICKÉHO BEZPEČNOSTNÍHO INCIDENTU

§ 14

(1)

Povinná osoba [Povinná osoba](#) pro potřeby vyhodnocení významnosti dopadu kybernetického bezpečnostního incidentu [kybernetického bezpečnostního incidentu](#) na poskytování regulované služby [regulované služby](#) stanoví

a)

únosnou míru újmy způsobené kybernetickým bezpečnostním incidentem [kybernetickým bezpečnostním incidentem](#), v jehož důsledku ještě není ohrožen život nebo zdraví osob nebo schopnost povinné osoby [povinné osoby](#) dostát svým závazkům,

b)

oblasti pro posouzení významnosti dopadu kybernetických bezpečnostních incidentů [kybernetických bezpečnostních incidentů](#) zohledňující zejména

1.

provozní dopad kybernetického bezpečnostního incidentu [kybernetického bezpečnostního incidentu](#) na povinnou osobu [povinnou osobu](#) a její schopnost poskytovat regulovanou službu [regulovanou službu](#),

2.

množství uživatelů [uživatelů](#) regulované služby [regulované služby](#) a jiných orgánů a osob zasažených kybernetickým bezpečnostním incidentem [kybernetickým bezpečnostním incidentem](#),

3.

časové, lidské a technické zdroje, které jsou potřebné k obnově poskytování zasažené regulované služby [regulované služby](#),

4.

typ a umístění aktiv [aktiv](#) dotčených kybernetickým bezpečnostním incidentem [kybernetickým bezpečnostním incidentem](#),

5.

citlivost informací [informací](#) a dat [dat](#) zasažených kybernetickým bezpečnostním incidentem [kybernetickým bezpečnostním incidentem](#) a újmu, jakou může narušení bezpečnosti těchto informací [informací](#) a dat [dat](#) způsobit povinné osobě [povinné osobě](#) nebo jinému orgánu nebo osobě, a

6.

přímou příčinu kybernetického bezpečnostního incidentu [kybernetického bezpečnostního incidentu](#), je-li povinné osobě [povinné osobě](#) známo, zda se jedná o lidskou chybu, technickou závadu nebo úmyslné jednání.

(2)

Dopad kybernetického bezpečnostního incidentu [kybernetického bezpečnostního incidentu](#) na poskytování regulované služby [regulované služby](#) je považován za významný, pokud

a)

přesáhne povinnou osobou [povinnou osobou](#) stanovenou únosnou míru újmy způsobenou kybernetickým bezpečnostním incidentem [kybernetickým bezpečnostním incidentem](#) podle [odstavce 1 písm. a\)](#) a současně

b)

je oblast pro posouzení významnosti dopadu podle [odstavce 1 písm. b\)](#) posouzena jako významná.

ČÁST ČTVRTÁ

ÚČINNOST

§ 15

Účinnost

Tato vyhláška nabývá účinnosti dnem 1. listopadu 2025.

Ředitel:

Ing. Kintr v. r.

Příloha č. 1

Přehled bezpečnostních opatření

Tato příloha představuje přehled bezpečnostních opatření [bezpečnostních opatření](#) ve formě tabulky ([Tab. č. 1](#)), která má povinné osobě [povinné osobě](#) sloužit jako nástroj k vyhodnocení účinnosti zavedených bezpečnostních opatření [bezpečnostních opatření](#) za stanovené období.

Tab. č. 1: Přehled bezpečnostních opatření

Vyhodnocení účinnosti zajišťování kybernetické bezpečnosti

Bezpečnostní opatření podle vyhlášky	Stav bezpečnostního opatření	Popis bezpečnostního opatření	Termín zavedení bezpečnostního opatření	Priorita zavedení bezpečnostního opatření	Odpovědnost bezpečnostního opatření
--------------------------------------	------------------------------	-------------------------------	---	---	-------------------------------------

Přehled bezpečnostních opatření [bezpečnostních opatření](#) je složen ze šesti sloupců, kdy specifiky jednotlivých sloupců a příklady jejich vyplnění jsou uvedeny v tabulkách níže ([Tab. č. 2 až 7](#)). V [Tabulce č. 3](#) „Stav bezpečnostního opatření [bezpečnostního opatření](#)“ jsou místo příkladů uvedeny „Přípustné hodnoty“.

Tab. č. 2: Bezpečnostní opatření podle vyhlášky

Název sloupce v Tab. č. 1	Bezpečnostní opatření Bezpečnostní opatření podle vyhlášky.
Popis sloupce	Příslušné bezpečnostní opatření bezpečnostní opatření požadované vyhláškou uveďte například formou odkazu na dotčené ustanovení vyhlášky.
Popis hodnot	Uvedené hodnoty musí odkazovat na konkrétní ustanovení právního předpisu, pokud je doporučeno, aby byly jednotlivé části uvedeny v logické návaznosti.

Tab. č. 3: Stav bezpečnostního opatření

Název sloupce v Tab. č. 1	Stav bezpečnostního opatření bezpečnostního opatření .
Popis sloupce	Popis stavu bezpečnostního opatření bezpečnostního opatření ve chvíli, kdy je pro vyhodnocení účinnosti zajišťování kybernetické bezpečnosti.
Popis hodnot	Tento sloupec bude obsahovat právě jednu z přípustných hodnot „Zavedeno“, „V procesu“ nebo „Nezavedeno“.

Hodnotu „Zavedeno“ lze zapsat v případě, kdy bylo bezpečnostní opatření [bezpečnostního opatření](#) v hodnoceném období zavedeno v požadovaném rozsahu.

Hodnotu „V procesu“ lze zapsat v případě, kdy je bezpečnostní opatření [bezpečnostního opatření](#) (nebo jeho část) v hodnoceném období zaváděno, popřípadě jsou činěny doložitelné kroky k jeho zavedení (například výběrové řízení, smlouva, testovací j

Hodnotu „Nezavedeno“ lze zapsat pouze v případě, kdy opatření zavedeno nebylo.

Tab. č. 4: Popis bezpečnostního opatření

Název sloupce v Tab. č. 1	Popis bezpečnostního opatření bezpečnostního opatření .
Popis sloupce	Stručný popis zavedení bezpečnostního opatření bezpečnostního opatření v návaznosti na stav, v jakém se aktuálně nachází, a s přihlédnutím k prostředí povinné osoby povinné osoby .
Popis hodnot	Popis jednotlivých bezpečnostních opatření bezpečnostních opatření by měl stručně reflektovat situaci u povinné osoby povinné osoby (například podle názvu příslušné bezpečnostní dokumentace) a stav bezpečnostního opatření bezpečnostního opatření Tab. č. 2 .

V případě bezpečnostních opatření [bezpečnostních opatření](#), která jsou označena jako „V procesu“ je nutné popsat prozatímní stav, případně uvést odkaz na dokumentaci, která dokládá proces zavádění.

Pokud je bezpečnostní opatření [bezpečnostní opatření](#) označeno jako „Nezavedeno“, je nutné odůvodnit, proč zavedeno nebylo.

Tab. č. 5: Termín zavedení bezpečnostního opatření

Název sloupce v Tab. č. 1	Termín zavedení bezpečnostního opatření bezpečnostního opatření .
---	---

Popis sloupce	Plánovaný termín zavedení bezpečnostního opatření bezpečnostního opatření v p rozsahu.
Popis hodnot	Tato hodnota bude vyplněna pouze v případě, je-li stav bezpečnostního opatření bezpečnostního opatření označen jako „V procesu“ nebo „Nezavedeno“, zavedení je v budoucnu plánováno nebo závisí na dalších okolnostech. Měla by b uvedena buď konkrétním datem nebo kvartálem či měsícem konkrétního roku.

Tab. č. 6: Priorita zavedení bezpečnostního opatření

Název sloupce v Tab. č. 1	Priorita zavedení bezpečnostního opatření bezpečnostního opatření .
Popis sloupce	Prioritizace zavádění bezpečnostních opatření bezpečnostních opatření s ohleden dopad na poskytování regulované služby regulované služby .
Popis hodnot	Hodnotu „nízká“ nebo „1“ je možné zapsat v případě, kdy by absence zavedení bezpečnostního opatření bezpečnostního opatření neměla dopad na poskytování regulované služby regulované služby nebo dané bezpečnostní opatření bezpečnostního opatření není pro poskytování regulované služby regulované služby relevantní. Hodnotu „střední“ nebo „2“ je možné zapsat v případě, kdy by absence zavedení bezpečnostního opatření bezpečnostního opatření měla minimální a krátkodobý c poskytování regulované služby regulované služby. Hodnotu „vysoká“ nebo „3“ je možné zapsat v případě, kdy by absence zavedení bezpečnostního opatření bezpečnostního opatření měla za následek vážný a dlouh dopad na poskytování regulované služby regulované služby. Hodnotu „kritická“ nebo „4“ je možné zapsat v případě, kdy by absence zavedení bezpečnostního opatření bezpečnostního opatření měla okamžitě a nevratně důsl poskytování regulované služby regulované služby nebo jsou známy úspěšné poku: překonání bezpečnostních opatření bezpečnostních opatření.

Tab. č. 7: Odpovědnost za bezpečnostní opatření

Název sloupce v Tab. č. 1	Odpovědnost za bezpečnostní opatření bezpečnostní opatření .
Popis sloupce	Osoba pověřená za zavedení daného bezpečnostního opatření bezpečnostního op
Popis hodnot	Je nutné zaznamenat údaje tak, aby bylo možné jednoznačně určit osobu pověřen zavedení bezpečnostního opatření bezpečnostního opatření . V případě potřeby je uvést také konkrétní organizační složku, do níž daná osoba spadá.

Příloha č. 2

Požadavky na smluvní ujednání s dodavateli

Povinná osoba [Povinná osoba](#) uzavírá pouze takové smlouvy, které stanoví způsoby realizace bezpečnostních opatření [bezpečnostních opatření](#) a určují obsah vzájemné smluvní odpovědnosti za zavedení a kontrolu bezpečnostních opatření [bezpečnostních opatření](#).

Povinné osoby [Povinné osoby](#) mohou uzavírat jen takové smlouvy, které budou zohledňovat následující relevantní ustanovení:

- a) ustanovení o bezpečnosti informací [bezpečnosti informací](#) z pohledu důvěrnosti (včetně ustanovení o mlčenlivosti), integrity a dostupnosti,
- b) ustanovení o auditu dodavatele související s plněním smlouvy,
- c) ustanovení o řetězení dodavatelů,
- d) ustanovení upravující tzv. exit strategii, podmínky ukončení smluvního vztahu z pohledu bezpečnosti informací [bezpečnosti informací](#),
- e) ustanovení o sankcích za porušení smluvních povinností,
- f)

ustanovení o oprávnění užívat data[data](#),

g)

ustanovení o autorství programového kódu, případně o programových licencích,

h)

ustanovení o důvěrnosti smluvního vztahu,

i)

ustanovení o povinnosti dodavatele dodržovat bezpečnostní politiky povinné osoby [povinné osoby](#) nebo ustanovení o odsouhlasení bezpečnostních politik [bezpečnostních politik](#) dodavatele (nebo odsouhlasení pro dodavatelský vztah relevantních částí bezpečnostních politik [bezpečnostních politik](#)) povinnou osobou [povinnou osobou](#),

j)

ustanovení o řízení změn,

k)

ustanovení o kybernetických bezpečnostních incidentech [kybernetických bezpečnostních incidentech](#) souvisejících s plněním smlouvy,

l)

ustanovení upravující zajištění řízení kontinuity činností,

m)

náležitosti smlouvy o úrovni služeb (SLA) a způsobu a úrovni realizace bezpečnostních opatření [bezpečnostních opatření](#),

n)

ustanovení o dodržování pravidel bezpečného vývoje.

Povinná osoba [Povinná osoba](#) může požadovat při uzavírání smluv s dodavateli i další ujednání zohledňující specifické požadavky plynoucí ze zajištění provozních a bezpečnostních potřeb souvisejících s regulovanou službou [regulovanou službou](#), která nejsou uvedena v této příloze.

Příloha č. 3

Témata pro rozvoj bezpečnostního povědomí

a)

Techniky zabezpečení zařízení.

b)

Firewall, antivirový program a jejich omezení.

c)

Škodlivé programy a jejich projevy.

d)

Rizika stahování programů a aplikací.

e)

Aktualizace software.

f)

Rizika povolení a zakázání spouštění maker.

g)

Rizika spustitelných souborů.

h)

Zásady zabezpečení uživatelských účtů.

i)

Používání, tvorba a správa hesel.

j)

Vícefaktorová autentizace.

k)

Techniky sociálního inženýrství.

l)

On-line identita, digitální stopa a její minimalizace.

m)

Zásady práce v počítačové síti.

n)

Používání vzdáleného připojení (VPN).

o)

Bezpečná elektronická komunikace.

p)

Bezpečnost webových stránek.

q)

Zálohování, ukládání a šifrování dat [dat](#).

r)

Bezpečné používání přenosných technických nosičů dat [dat](#).

s)

Využívání služeb cloud computingu [služeb cloud computingu](#).

t)

Pravidla a postupy pro oznamování neobvyklého chování technických aktiv [technických aktiv](#) a podezření na jakékoliv zranitelnosti [zranitelnosti](#).

u)

Základní postup při reakci na kybernetickou bezpečnostní událost [kybernetickou bezpečnostní událost](#) nebo kybernetický bezpečnostní incident [kybernetický bezpečnostní incident](#).

v)

Zásady bezpečného používání pracovních zařízení pro soukromé účely.

w)

Zásady bezpečného používání soukromých zařízení pro pracovní účely (tzv. BYOD).

x)

Osobní odpovědnost zaměstnance při dodržování zásad kybernetické bezpečnosti.

y)

Aktuální hrozby [hrozby](#) v kybernetické bezpečnosti.

1)

Směrnice Evropského parlamentu a Rady (EU) [2022/2555](#) ze dne 14. prosince 2022 o opatřeních k zajištění vysoké společné úrovně kybernetické bezpečnosti v Unii a o změně nařízení (EU) č. [910/2014](#) a směrnice (EU) 20/1972 a o zrušení směrnice (EU) [2016/1148](#) (směrnice NIS 2).